

Smart Contract Audit Report

Round 3 · Final Review

MoonsaleFairLaunch + Factory

Prepared for Moonsale App

BNB Smart Chain · Solidity ^0.8.20

Report ID	ICGH-2026-MSFL-003
Prior Reports	MSFL-001 (R1) · MSFL-002 (R2)
Client	Moonsale App
Scope	MoonsaleFairLaunch.sol + Factory.sol + Interface
On-chain Refs	Sepolia 0x0aD0...6056 · BSC-T 0x7064...209e
Commit / Ver.	pragma ^0.8.20 · evmVersion paris · runs 200
Methodology	Full re-review, factory coverage, regression check
Issue Date	April 23, 2026

Executive Summary

This report is the final review in a three-round engagement covering the Moonsale fair launch product on BNB Smart Chain. Round 3 incorporates the factory source that was previously out of scope, converting earlier assumption-based conclusions into verified findings, and re-assesses the full surface against the latest revision of `MoonsaleFairLaunch.sol`, `MoonsaleFairLaunchFactory.sol`, and `IMoonsaleFairLaunch.sol`.

All Critical, High, and Medium findings raised in the prior rounds are either resolved or formally acknowledged. Factory coverage confirms the balance-snapshot deposit pattern (strict equality check rejects fee-on-transfer tokens at intake), the pull-based listing fee accumulator, the independent liquidity locker with extendable lock duration, the emergency pause, and the excess-ETH refund path. Each of these meets the security properties that Round 2 assumed.

New findings in Round 3 concentrate on factory-side hygiene: single-step ownership transfer, a missing event on `sweepStuckETH`, pagination on registry reads, and a small set of informational observations around owner privileges and pre-deposit edge cases. None rise above Low severity.

The contract set meets a production-grade security bar. After implementing the remaining Low-priority hygiene items, the deliverable is suitable for mainnet deployment on BNB Smart Chain and for EVM-compatible networks referenced in the client brief.

Findings Overview (Round 3)

Severity	Count	Description
Critical	0	Direct loss of user or protocol funds, or unilateral takeover
High	0	Realistic exploit with significant impact
Medium	1	Acknowledged design decision carried forward
Low	6	Limited impact; defence-in-depth
Informational	9	Code quality, gas, documentation

Security Score Progression

Round	Score	Notable change
R1 (MSFL-001)	62 / 100	Baseline review
R2 (MSFL-002)	88 / 100	Both Highs resolved; most Mediums resolved
R3 (MSFL-003)	92 / 100	Factory verified; L-04 and L-06 resolved

92 / 100

The contract set demonstrates strong engineering discipline across the full life-cycle. Residual items are hygiene, documentation, and one accepted design decision. No fund-loss exposure remains in the reviewed code paths.

Scope and Methodology

Files in Scope

File	Role	Reviewed
MoonsaleFairLaunch.sol (479 lines)	Fair launch clone, full lifecycle	Yes
MoonsaleFairLaunchFactory.sol (310 lines)	Factory, liquidity locker, platform config	Yes
IMoonsaleFairLaunch.sol (41 lines)	Events, enums, signatures	Yes

Round 3 Methodology

- Full re-review of the clone source against Round 2 observations, confirming all reported remediations and checking for regressions.
- First-time review of the factory: deployment flow, access control, accounting of accumulated listing fees, lock record lifecycle, and rescue functions.
- Cross-contract analysis of invariants that span clone and factory: token deposit snapshot, LP lock ownership, and factory configuration propagation at initialisation.
- CEI audit of every function that moves value: `createFairLaunchAndDeposit`, `finalize`, `claim`, `withdrawContribution`, `refund`, `emergencyRefund`, `unlockLiquidity`, `claimListingFees`, `sweepStuckETH`.
- State machine verification for all reachable transitions with particular attention to the newly added `creationPaused` gate and the separate `EmergencyCancelled` event.
- Verified on-chain source on Sepolia and BSC Testnet matches the audited files.

Findings Resolution — Full History

The table below consolidates every finding raised across all three rounds with its final Round 3 status.

ID	Severity	Status	Notes
H-01	High	RESOLVED	emergencyRefund() verified; 30-day grace; CEI-compliant
H-02	High	RESOLVED	Reserve pre-check verified; residual as L-07
M-01	Medium	RESOLVED	Factory strict-equality check rejects FoT at intake
M-02	Medium	ACKNOWLEDGED	Creator cancel after softcap; design decision
M-03	Medium	RESOLVED	Factory verified: token escrow atomic with clone
M-04	Medium	RESOLVED	(usedToken, usedETH) fold-back verified
L-01	Low	OPEN	Rounding dust on claims; minor
L-02	Low	OPEN	Token decimals in price view; integrator concern
L-03	Low	RESOLVED	200-address whitelist batch cap
L-04	Low	RESOLVED	WhitelistToggled + WhitelistChanged events added
L-05	Low	OPEN	minBuy carve-out at wallet cap; documented
L-06	Low	RESOLVED	Strict received == depositAmount check
L-07	Low	OPEN	Persistent pair grieving; availability only
L-08	Low	OPEN	emergencyRefund documentation
L-09	Low	NEW	Factory uses single-step Ownable
L-10	Low	NEW	sweepStuckETH emits no event
I-01	Informational	OPEN	Unchecked increment on counters
I-02	Informational	OPEN	Factory penalty params read live during withdraw
I-03	Informational	OPEN	receive() accepts arbitrary ETH
I-04	Informational	OPEN	Hard-coded 10-min router deadline
I-04b	Informational	RESOLVED	WhitelistToggled event
I-05	Informational	OPEN	Redundant Pending/Active branch
I-06	Informational	OPEN	NatSpec coverage
I-07	Informational	RESOLVED	EmergencyCancelled event added
I-08	Informational	NEW	Ownable renounceOwnership exposed
I-09	Informational	NEW	getAllFairLaunches unbounded return
I-10	Informational	NEW	participantCount not decremented in refund paths
I-11	Informational	NEW	Pre-deposited tokens to clone are stuck after finalize
I-12	Informational	NEW	LockExtended event lacks new unlockTime context
I-13	Informational	NEW	Implementation contract can receive ETH

Factory Verification Notes

This section documents the first-pass review of MoonsaleFairLaunchFactory, since the file was previously listed under Out of Scope.

Deposit and initialization flow

`createFairLaunchAndDeposit` clones the implementation, snapshots the clone's token balance before and after `safeTransferFrom`, and requires `received == depositAmount`. This is a strict equality that rejects any token with a transfer fee, reflexive rebase, or proxy-burn behaviour. The factory overrides platform parameters (`platformFeePercent`, `platformFeeRecipient`, `dexRouter`, `creator`) on the `params` struct before calling `initialize`, preventing a creator from injecting non-canonical values. Registry writes follow the external calls, and the excess-ETH refund closes the function under the `nonReentrant` modifier. M-01 and M-03 from Round 1 are formally verified here.

Listing fee accounting

`accumulatedListingFees` is incremented by exactly `listingFeeNative` per creation, and decremented atomically to zero inside `claimListingFees` before the external call. `sweepStuckETH` computes `balance - accumulatedListingFees`, guarded by `require(balance > accumulatedListingFees)`, which prevents the owner from sweeping protocol fees. The pull pattern correctly isolates creation from recipient liveness, closing the Round 1 M-02 concern about push-payment DoS.

Liquidity locker

`lockLiquidity` is gated by `isFairLaunch[msg.sender]`, so only clones deployed by this factory can register locks. `unlockLiquidity` sets `withdrawn = true` before transfer, preserving CEI. `extendLock` enforces `newUnlockTime > lock.unlockTime`, making locks strictly non-decreasing in duration. `nonReentrant` covers both lock and unlock. The lock record array is append-only.

Emergency controls

`creationPaused` gates only new creations. Pausing has no effect on existing fair launches, which continue to operate independently. `sweepStuckETH` sends to `platformFeeRecipient` rather than an arbitrary address, reducing misuse surface. Both controls are owner-only and consistent with the platform's stated operational model.

Findings Outstanding and New

Medium Severity

MEDIUM

M-02 Creator can cancel after softcap reached (acknowledged)

Status. Acknowledged design decision. Unchanged.

Description. `cancelFairLaunch()` allows the creator to transition to Cancelled while status is Pending or Active, regardless of `totalRaised` vs `softcap`. Contributors recover principal through `refund()`, but the creator retains a cancellation option after observing contribution dynamics.

Recommendation. If retained, document prominently in user-facing materials so contributors understand that cancellation is possible until `finalize` is called.

Low Severity

LOW

L-09 Factory uses single-step Ownable (new)

Description. `MoonsaleFairLaunchFactory` extends `OpenZeppelin Ownable`, which exposes a single-step `transferOwnership`. Since the factory accumulates listing fees and holds LP tokens that can only be unlocked through its API, an accidental transfer to a wrong address is unrecoverable. Given the long-lived nature of the contract and the value it custodies, a two-step handover pattern is warranted.

Recommendation. Replace `Ownable` with `Ownable2Step`. This requires the incoming owner to explicitly accept the role before it takes effect, which protects against typos and compromised clipboards.

LOW

L-10 sweepStuckETH emits no event (new)

Description. `sweepStuckETH` moves native currency out of the factory without emitting any event. Off-chain observers cannot distinguish a sweep from legitimate fee claims or construct an audit trail for treasury reconciliation.

Recommendation. Add event `StuckETHSwept(address indexed recipient, uint256 amount)` and emit it before the external call inside `sweepStuckETH`.

LOW

L-01 Rounding dust on token claims (carried forward)

Status. Unchanged. Post-finalize dust is low percentage given `investorTokenPool` absorbs any router residual.

Recommendation. Add a time-locked creator sweep after a grace period beyond `finalizedAt`, or document the rounding behaviour in `NatSpec`.

LOW

L-02 Price view function ignores token decimals (carried forward)

Recommendation. Cache `decimals()` at initialisation and scale `getEstimatedTokenPrice`, or rename to reflect the base-unit semantics.

LOW

L-05 minBuy carve-out at wallet cap (carried forward)

Recommendation. Either document the behaviour or apply `minBuy` unconditionally on the accepted portion.

LOW

L-07 Persistent DEX pair griefing (carried forward)

Recommendation. Extend the factory with an atomic pair-creation and seed-at-fair-price flow, or expose a price-alignment swap invocable by the creator before `finalize()`.

LOW

L-08 emergencyRefund documentation (carried forward)

Recommendation. Publish the 30-day grace period and its consequences (unilateral cancel by any party, even after softcap is reached) in user-facing materials and factory UI.

Informational

INFORMATIONAL**I-01 Unchecked arithmetic on counters (carried forward)**

Recommendation. Wrap `participantCount++` and the decrement in `withdrawContribution` in unchecked blocks to save gas.

INFORMATIONAL**I-02 Factory penalty parameters read live (carried forward)**

Recommendation. Cache `penaltyPercent` and `penaltyReceiver` at clone initialisation to avoid mid-sale policy changes.

INFORMATIONAL**I-03 `receive()` accepts arbitrary ETH (carried forward)**

Recommendation. Either tighten `receive()` or route unsolicited ETH to `platformFeeRecipient` with an event.

INFORMATIONAL**I-04 Hard-coded 10-minute router deadline (carried forward)**

Recommendation. Promote the deadline to a named constant or per-clone parameter for portability across chains.

INFORMATIONAL**I-05 Redundant Pending / Active guard in `contribute` (carried forward)**

Recommendation. Collapse the dual-status check into one clause.

INFORMATIONAL**I-06 `NatSpec` coverage (carried forward, partial)**

Recommendation. Add `NatSpec` to `emergencyRefund`, whitelist functions, factory owner-only setters, and every view getter.

INFORMATIONAL**I-08 `Ownable.renounceOwnership` exposed (new)**

Recommendation. If the factory is renounced, accumulated listing fees and platform configuration become unrecoverable. Consider overriding `renounceOwnership` to revert, or document the operational policy explicitly.

INFORMATIONAL**I-09 `getAllFairLaunches` returns unbounded array (new)**

Recommendation. Replace with a paginated getter `getFairLaunchesPaged(uint256 start, uint256 count)`. Existing getters are fine for registry indexing but become costly off-chain as the platform scales.

INFORMATIONAL**I-10 `participantCount` not decremented in refund paths (new)**

Recommendation. `withdrawContribution` decrements the counter, but `refund` and `emergencyRefund` do not. On a failed or cancelled sale the counter overstates participation. The client has confirmed the field is informational only, so this is a cosmetic inconsistency.

INFORMATIONAL**I-11 Tokens pre-deposited to a clone are stuck after `finalize` (new)**

Recommendation. If anyone sends tokens directly to the clone between initialisation and finalisation, those tokens are not included in `investorTokenPool` and remain in the contract after a successful `finalize`. A failed `finalize` lets the creator sweep them via `withdrawCreatorTokens`, but the successful-path leak is permanent. Consider recomputing the investor pool against actual contract balance at `finalize`.

INFORMATIONAL**I-12 `LockExtended` event lacks previous `unlockTime` (new)**

Recommendation. The event records only the new unlock time. Including the prior value would simplify off-chain reconciliation. Similarly, `LiquidityLocked` and `LiquidityUnlocked` could include `lockId` for direct correlation.

INFORMATIONAL

I-13 Implementation contract can receive ETH (new)

Recommendation. The implementation contract is initialiser-disabled, but its `receive()` fallback still accepts ETH. Any ETH sent directly is permanently stuck on the implementation. Remove `receive()` on the implementation or add a rescue path that only the factory owner can call.

Positive Observations (Round 3)

- Every finding classified as Critical, High, or Medium across three rounds has either been resolved in code or formally acknowledged. The security posture at the close of this engagement has no open fund-loss vectors.
- The factory's strict-equality deposit check (`require(received == depositAmount)`) is a cleaner fix than the defensive route of accepting the actual delta. It surfaces the incompatibility to the creator with an actionable error message and avoids silent pool shortfalls.
- The pull-based listing fee pattern (`accumulatedListingFees` plus `claimListingFees`) is the textbook solution to push-payment DoS and is implemented correctly with CEI ordering.
- `sweepStuckETH` correctly computes the sweep amount against `accumulatedListingFees`, preventing the owner from draining protocol fees under the guise of a rescue.
- `extendLock` enforces monotonically non-decreasing unlock time, which is the right asymmetry for an LP lock: owners can add commitment, never remove it.
- `emergencyRefund` integrates cleanly with the existing refund path by transitioning to the shared `Cancelled` status, and emits a dedicated `EmergencyCancelled(address indexed caller)` event so indexers can separate creator-initiated cancellations from rescue invocations.
- The reserve pre-check in `finalize` fails with an actionable error message that directs the creator to `cancelFairLaunch()`, which unblocks contributor refunds without requiring further creator input.
- `creationPaused` is the right operational kill-switch: it halts new creations without affecting any existing fair launch, so pausing the platform does not freeze in-progress user funds.
- CEI ordering is correct in every value-moving function across both clone and factory. Reentrancy is guarded by the clone's manual `_locked` (required by the proxy pattern) and by OpenZeppelin's `ReentrancyGuard` on the factory.
- Forced platform parameter overrides on the `params` struct inside `createFairLaunchAndDeposit` prevent a creator from bypassing factory governance by submitting custom values.

Out of Scope and Assumptions

All files listed in the client brief as in scope were provided and reviewed. The following components remain outside this report:

OpenZeppelin `SafeERC20`, `Initializable`, `ReentrancyGuard`, `Ownable`, `Clones`. Assumed at OpenZeppelin v5.0 or later.

DEX contracts. Assumed to be canonical PancakeSwap V2 deployments on BSC and canonical Uniswap V2 on Sepolia. `addLiquidityETH` semantics and `getReserves` behaviour are assumed to match Uniswap V2.

Separately audited components. `MoonsalePresale`, `MoonsaleFactory` (ICGH-MSL-2026-003), `MoonsaleToken*` series; frontend and database infrastructure.

Deployment configuration. Correct setting of `platformFeeRecipient`, `penaltyReceiver`, `minLiquidityLockDays`, `listingFeeNative` at factory deployment.

Recommended Remediation Order

No item on this list is blocking for mainnet deployment. The order reflects diminishing marginal return on hardening effort.

#	Finding	Effort	Priority
1	L-09 adopt Ownable2Step on factory	Trivial (0.5 day)	Medium
2	L-10 add StuckETHSwept event	Trivial (0.5 day)	Medium
3	M-02 publish cancellation policy	Trivial (doc)	Medium
4	L-08 publish emergencyRefund grace period	Trivial (doc)	Medium
5	L-07 factory-side pair price alignment	Medium (2 days)	Low
6	L-02 scale getEstimatedTokenPrice by decimals	Low (1 day)	Low
7	I-08 override renounceOwnership	Trivial (0.5 day)	Low
8	I-09 add paginated registry getter	Trivial (0.5 day)	Low
9	I-13 remove receive() from implementation	Trivial (0.5 day)	Low
10	Remaining hygiene (I-01 through I-12)	Low (1-2 days)	Low

Summary

The Moonsale fair launch contract set has progressed through three rounds of review with steady improvement. Round 1 identified two High and four Medium findings and scored 62 / 100. Round 2 closed both Highs and three Mediums, scoring 88 / 100. Round 3, with the factory source now in scope, resolves the remaining Medium (M-01 and M-03 become verified rather than assumed), closes Low findings L-04 and L-06, and introduces factory-specific findings at Low and Informational severity.

The final security score is 92 / 100. Addressing L-09, L-10, and the two documentation items (M-02, L-08) would close the remaining production hardening items without architectural change and push the score into the mid-nineties. Further gains would require changes to the DEX integration model (L-07) or the cancellation policy (M-02), which are judgement calls.

Deployment recommendation. The reviewed code is suitable for production deployment on BNB Smart Chain and the other EVM networks named in the client brief, subject to the two Low priority hardening items (L-09, L-10) and publication of the documentation items flagged in M-02 and L-08.

Disclaimer

This report is a point-in-time review of the source code provided in the Round 3 engagement, evaluated against the findings of ICGH-2026-MSFL-001, ICGH-2026-MSFL-002, and known vulnerability classes for EVM chains as of the issue date. It is advisory in nature and does not constitute financial, investment, legal, or tax advice.

No audit can guarantee the absence of vulnerabilities. Changes to the source code, deployment parameters, external dependencies (compiler version, OpenZeppelin libraries, DEX routers), or surrounding on-chain conditions after the issue date may introduce new risks not covered by this report.

ICOGemHunters accepts no liability for losses arising from the implementation or non-implementation of recommendations in this report, from vulnerabilities outside the reviewed scope, or from reliance on this report by third parties. Distribution of this document to parties other than the client named on the cover is permitted only with

written consent.

This engagement is complete. Extension to cover the Moonsale token, vesting, and separate lock contracts is available on request once those sources are submitted.